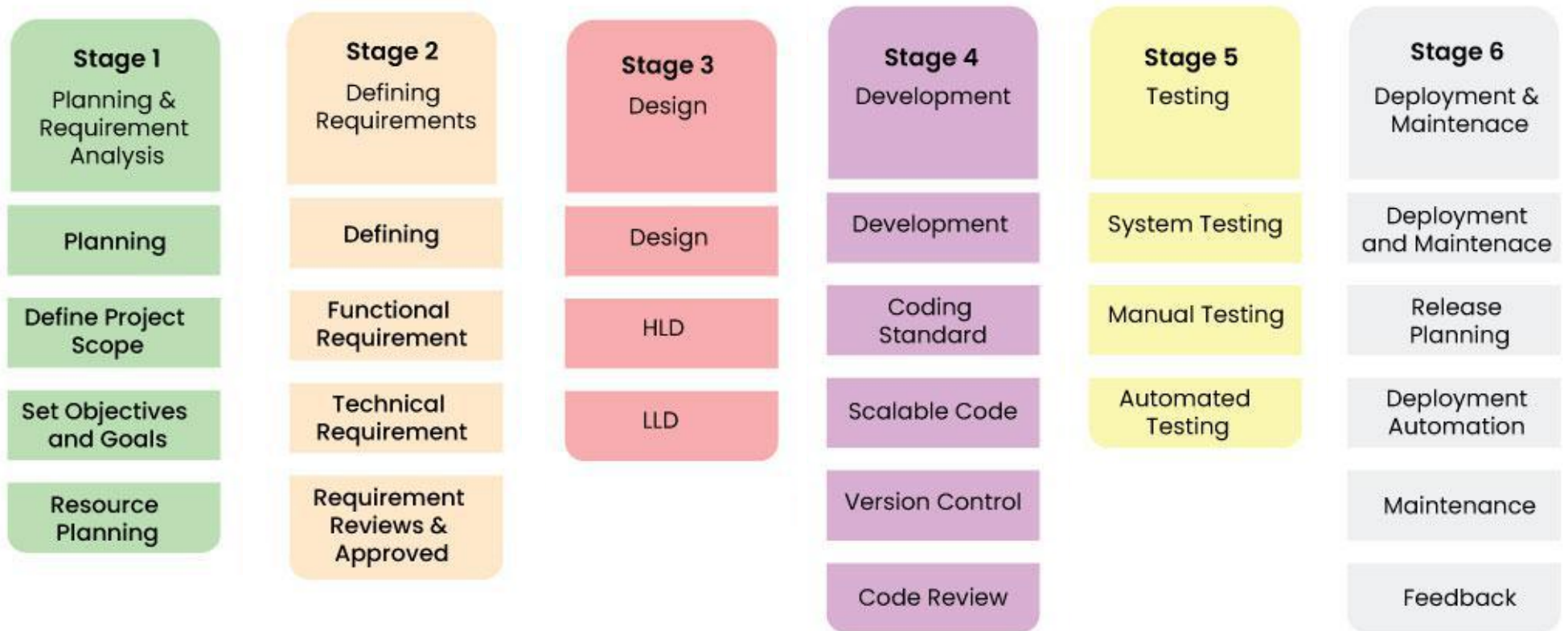


Secure Software Design and Engineering (CY-321)

You, Me, **Security** and SDLC

A Quick overview of SDLC



Waterfall Model (SDLC)

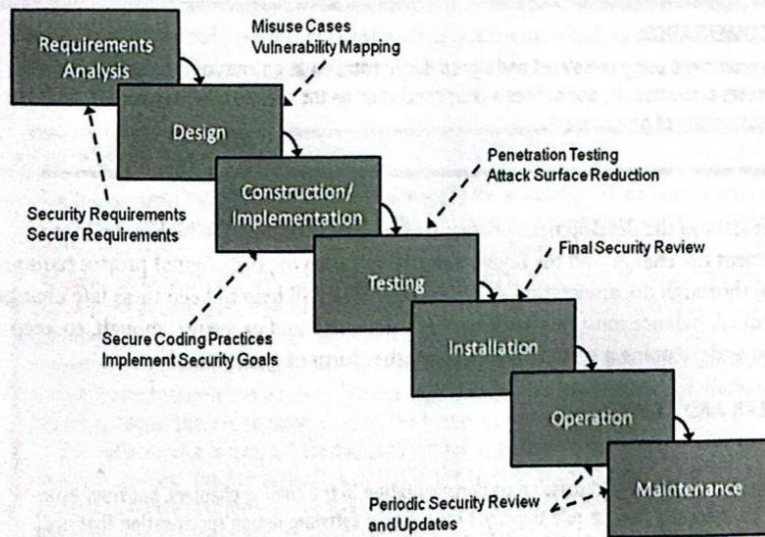


Figure 7.1

The waterfall model (SDLC) with security considerations.

- Tasks or activities into **six to eight** phases
- Cultural Change to adopt Security planning
- Scope of the project
- Functionality of the project
- Requirements of the project (Data, environment, etc)

Scope Creep



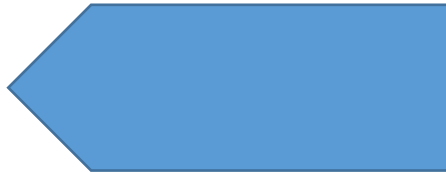
The **Why** in What and How

- Why did the **breach** happen?
- Why could they **access** it?
- Why wasn't **permission checking** implemented?
- Why didn't they know?
- Why wasn't it documented?

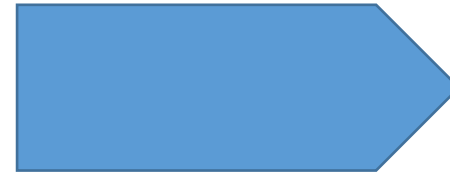
Why is Security Important in the SDLC?

Security related activities are deferred until the testing phase, which is late in the SDLC after most of the critical design and implementation has been completed

Shift Left



Shift Right



Planning and Requirement Stage

Security Requirements			
Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing & Timing	International	Procurement

Planning and Requirement Stage

Security Requirements			
Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing & Timing	International	Procurement

- Why should this **requirement** be part of the system?
- What are the constraints on this **requirement**?
- What are the dependencies for this **requirement**?
- What are the stakeholders for this **requirement**?

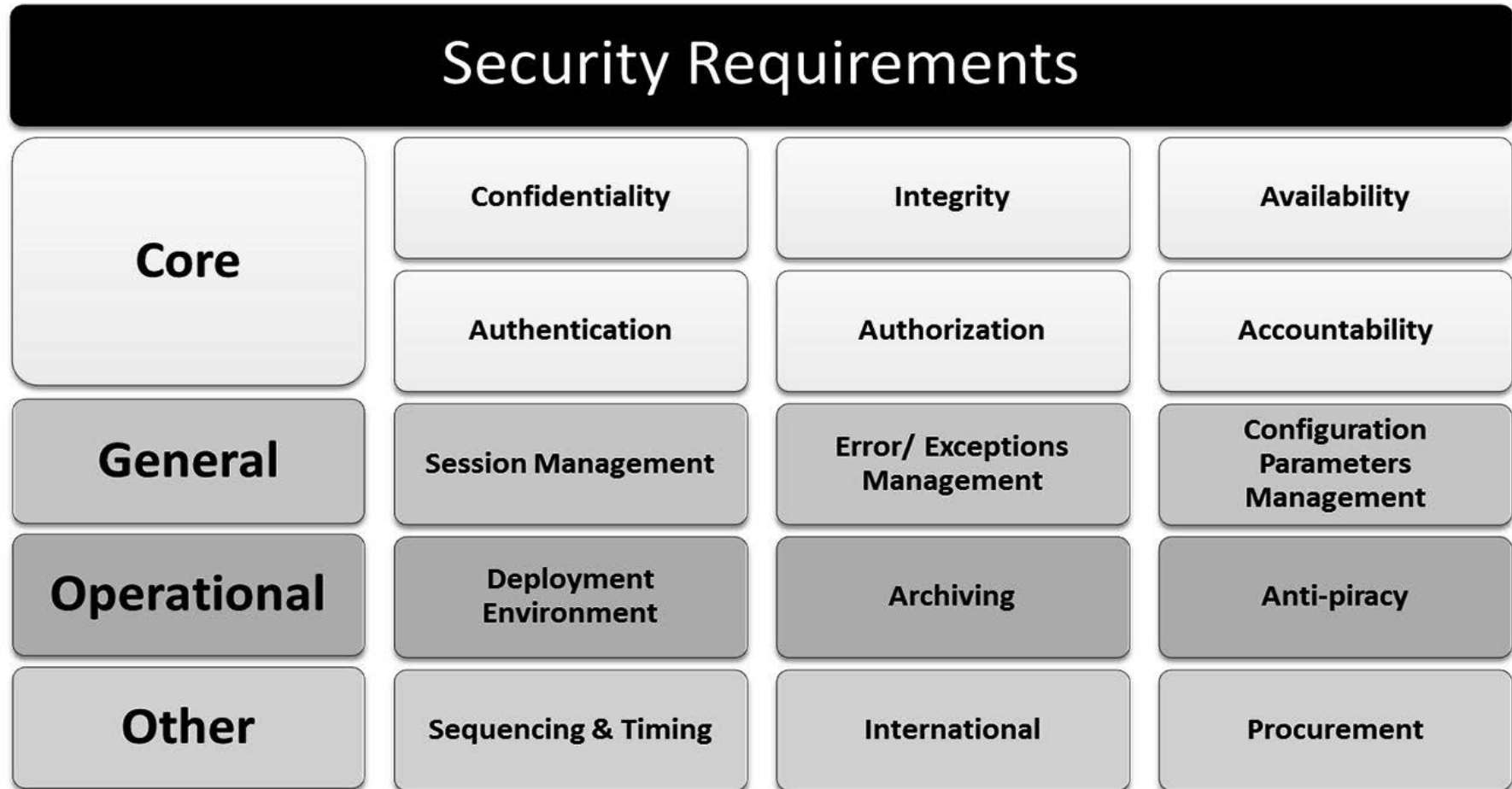
What if?

Fail Case

Result of Failure

Associated Risks

Planning and Requirement Stage



Planning and Requirement Stage

Confidentiality

Security Requirements			
Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing & Timing	International	Procurement

Address protection against the unauthorized disclosure of data or information that are either private or sensitive in nature

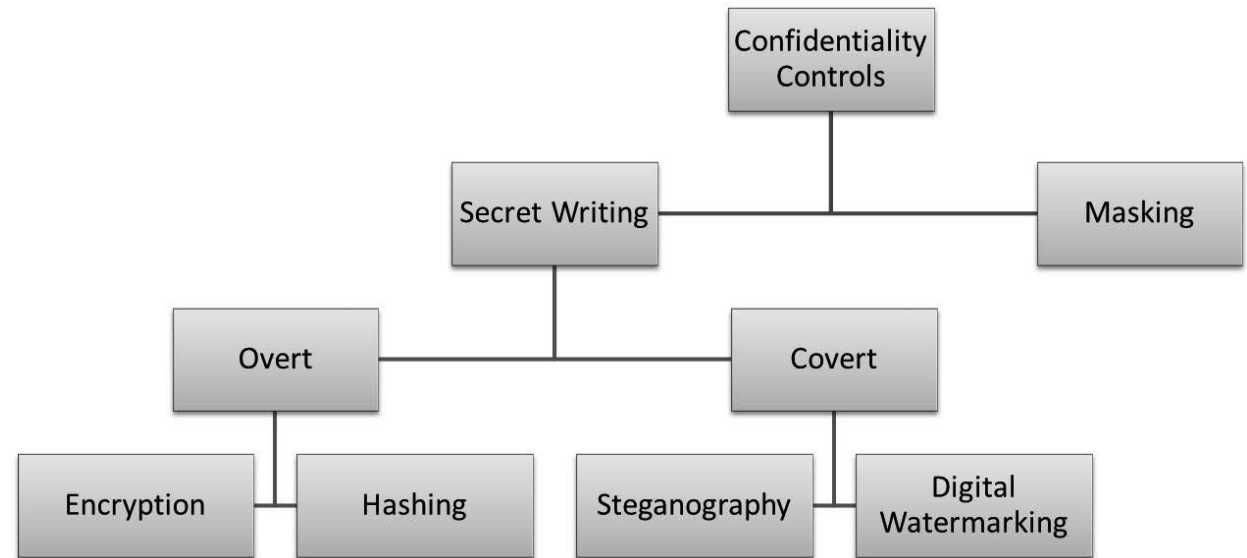
- **Data** can be broadly classified into **public** and **non-public data** or information.

Planning and Requirement Stage

Confidentiality

Security Requirements

Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing & Timing	International	Procurement



Planning and Requirement Stage

Confidentiality

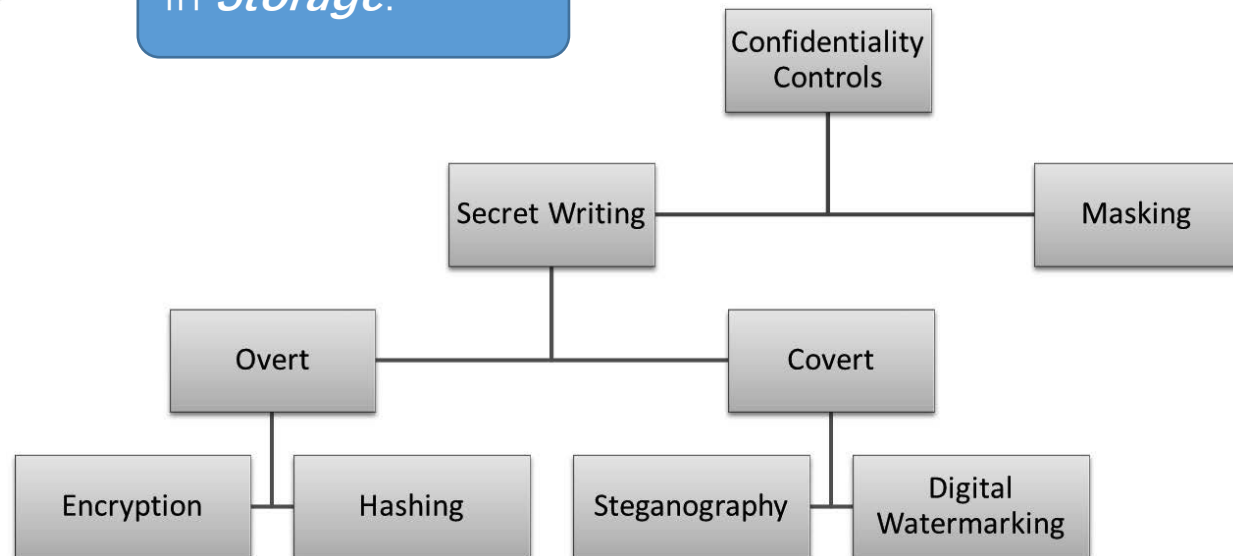
Security Requirements

Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing & Timing	International	Procurement

In *Transit*.

In *Processing*:

In *Storage*:



Planning and Requirement Stage

Integrity

Security Requirements

Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing & Timing	International	Procurement

System Integrity

Reliability assurance and protection

Data Integrity

Prevention against unauthorized modifications

Planning and Requirement Stage

Availability

Security Requirements			
Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing & Timing	International	Procurement

Maximum Tolerable Downtime (MTD)

Measure of the maximum amount of time that the software can be in a state of not providing expected service

Recovery Time Objective (RTO)

Amount of time by which the system or software needs to be restored back to the expected state of business operations

- MTD are sometimes are referred to as Maximum Tolerable Period of Disruption (MTPD)
- Adverse effects of software downtime through **Business Impact Analysis (BIA)**

Planning and Requirement Stage

Authentication

Security Requirements

Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing & Timing	International	Procurement

The process of validating an entity claim

- The entity may be a person, a process or a hardware device.

The most common forms of authentication??

Planning and Requirement Stage

Authorization

Security Requirements			
Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing & Timing	International	Procurement

Layered upon **authentication**, authorization requirements are those that confirm that an authenticated entity has the needed rights and privileges to access and perform actions on a requested resource

- CRUD operations, which stand for **Create, Read, Update or Delete** data

Impersonation and Delegation Model

Trusted Subsystem Model

Planning and Requirement Stage

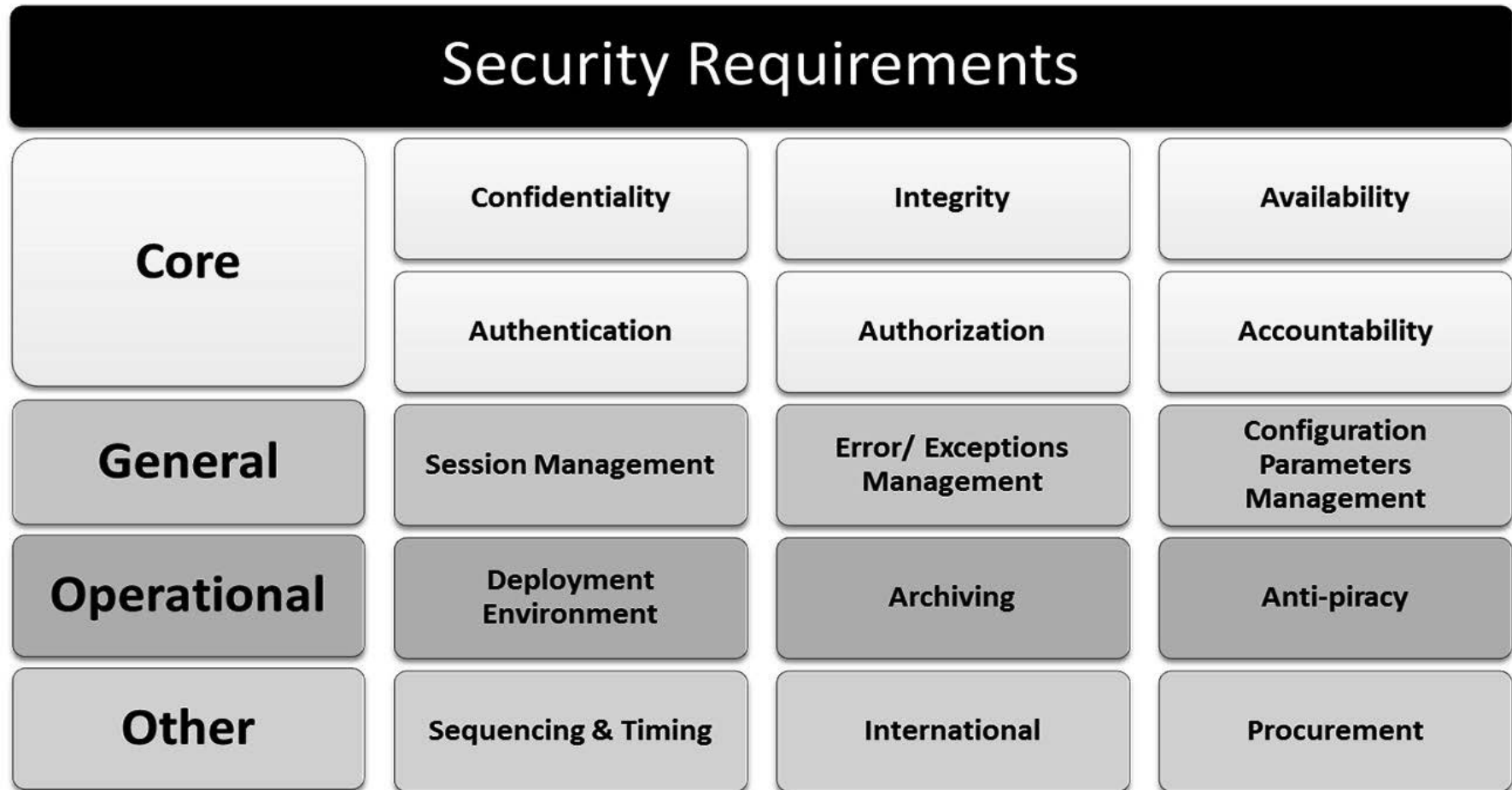
Accountability

Security Requirements

Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing & Timing	International	Procurement

- The identity of the subject (user or process) performing an action (**who**)
- The action (**what**)
- The object on which the action was performed (**where**)
- The timestamp of the action (**when**)

Planning and Requirement Stage



Planning and Requirement Stage

Session Management Requirements

Security Requirements			
Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing Timing	International	Procurement

Why we need session?

Related to which Secure Design concepts?

Since valid sessions can be potentially hijacked where an attacker takes control over an established session, it is necessary to plan for secure session management.

- Complete Mediation
- psychological acceptability

Planning and Requirement Stage

Errors & Exception Management Requirements

Security Requirements			
Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing & Timing	International	Procurement

All about how you handle and structure the errors and exception

Can Errors & exceptions are potential sources of information disclosure?

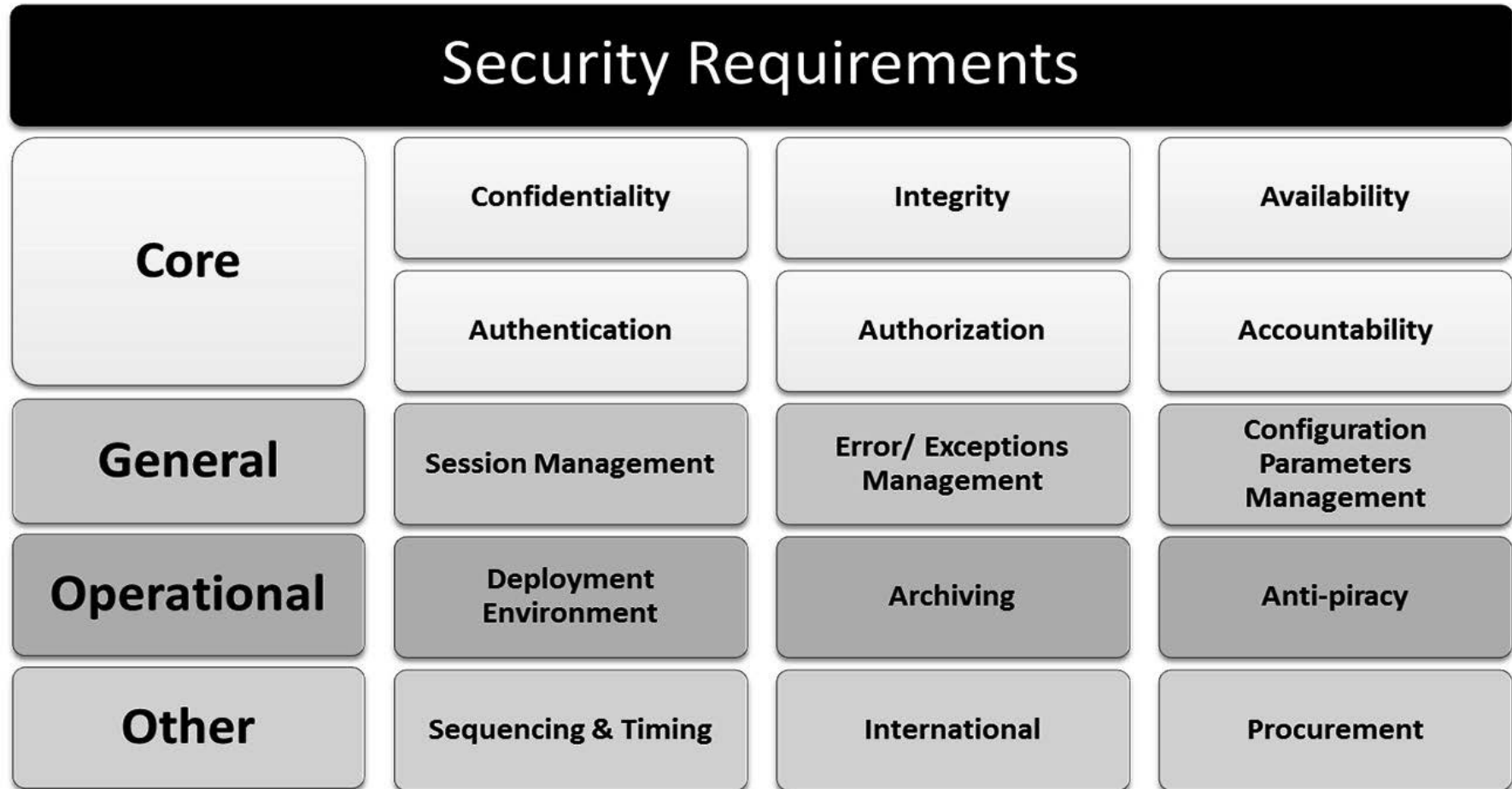
Planning and Requirement Stage

Configuration Parameters Management Requirements

Security Requirements

Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing & Timing	International	Procurement

Planning and Requirement Stage



Planning and Requirement Stage

Deployment Environment Requirements

Security Requirements

Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing & Timing	International	Procurement

Requirements about the environment in which the software will be deployed

Deployment Environment Requirements



Will the software be deployed in an **Internet**, **Extranet** or **intranet** environment?

Can we leverage existing operating system event logging for auditing purposes?

Will the software be load balanced and how is clustering architected?

What privileges will be allowed in the production environment?

Will the software be transmitting sensitive or confidential information?

Will the software be hosted in a Demilitarized Zone (DMZ)?

Will the software need to support single sign-on (SSO) authentication?

What ports and protocols are available for use?

Will the software be deployed in a **web farm environment**?

Planning and Requirement Stage

Archiving Requirements

Security Requirements			
Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing & Timing	International	Procurement

conflict between the organizational policy and a regulatory requirement, then follow?

the *location*, *duration* and *format* of archiving information must be determined

Archiving Requirements



Where will the data or information be stored?

How do we ensure that the media is not re-writable?

How long will we need to store the archives for?

Is there a regulatory requirement to store the data for a set period of time?

Is our archival retention policy contradictory to any compliance or regulatory requirements?

In what format will the data or information be stored? Clear text or cipher text?

If the data or information is stored in cipher text, how is this accomplished and are there management processes in place that will ensure proper retrieval?

How will these archives themselves be protected?

Planning and Requirement Stage

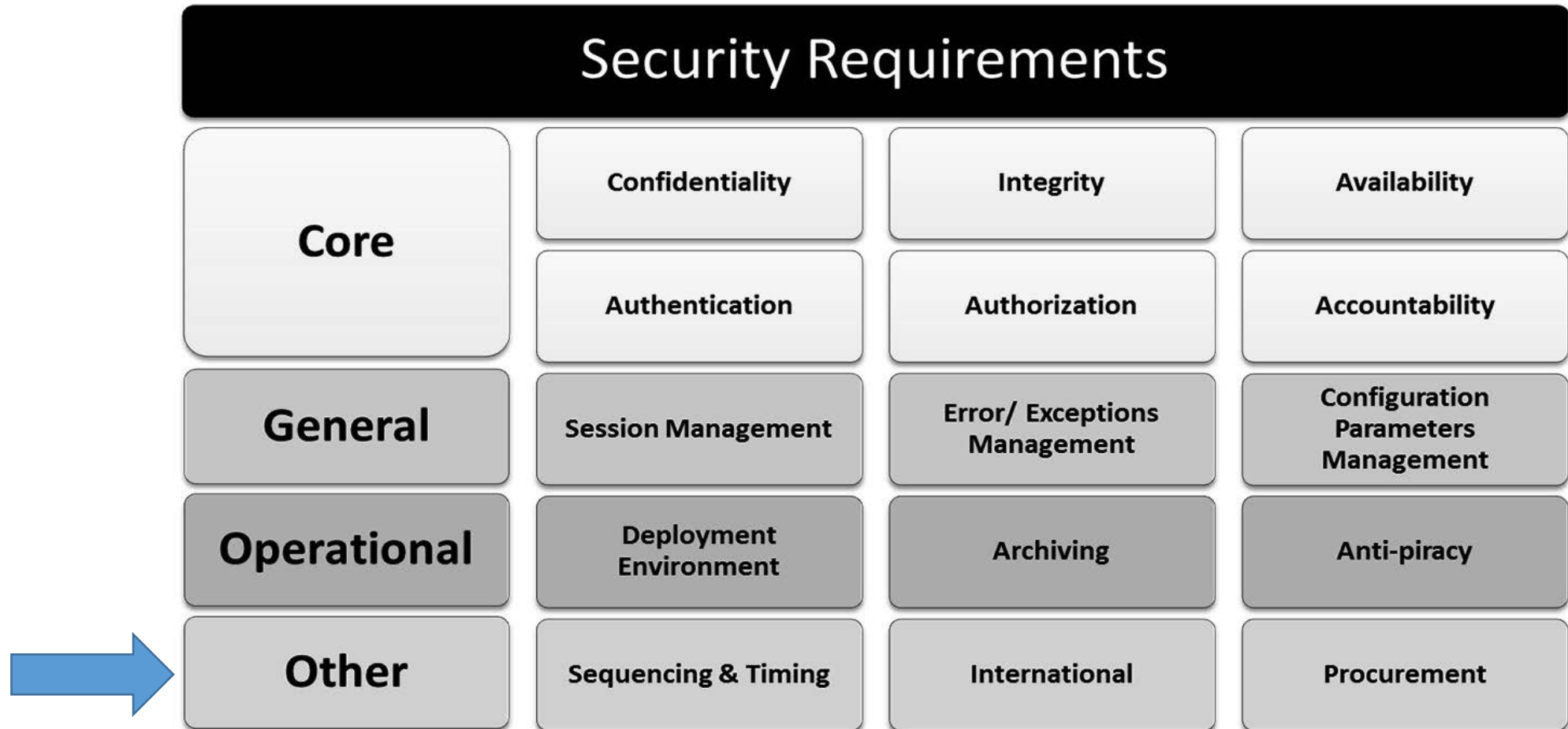
Anti-Piracy Requirements

Security Requirements

Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing & Timing	International	Procurement

Code obfuscation, anti-tampering, licensing and IP protection mechanisms should be included

Planning and Requirement Stage



Planning and Requirement Stage

Sequencing and Timing Requirements

Security Requirements			
Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing & Timing	International	Procurement

race conditions or
Time of Check/Time
of Use (TOC/TOU)
attacks.

Planning and Requirement Stage

International Requirements

Security Requirements			
Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing & Timing	International	Procurement

legal and technological.

Hospital Management System

Core	Confidentiality Lab results encrypted at rest and in transit	Integrity Digital signature verifies prescription wasn't altered	Availability Redundant servers keep records reachable in emergencies
	Authentication Staff login with ID, password, and OTP	Authorization Nurses view vitals; only doctors edit prescriptions	Accountability Every record access logged with user and time
	Session Management Shared workstation auto-logs out after 3 minutes	Error/Exceptions Mgmt Generic 'invalid credentials' message on failed login	Config Parameters Mgmt Default admin accounts disabled before go-live
	Deployment Environment New features tested on dummy data in staging	Archiving Patient records archived 7-10 years, then purged	Anti-piracy Imaging software requires license-key activation
General			
Operational			
Other	Sequencing & Timing Invoice generated only after treatment is marked done	International Complies with GDPR and HIPAA for cross-border data	Procurement Third-party lab API vendor must pass a security audit

Scenario



"A patient's data was leaked via an unencrypted API and you have them play the "why game" in groups, 5 rounds of "why?" until you land on a root cause."

Scenario



Vote only once by putting a cross ☒ in the box next to your choice

Should the United Kingdom remain a member of the European Union or leave the European Union?

Remain a member of the European Union

☐

Leave the European Union

☐

“Network Interactions should follow a stateful pattern to allow traffic anomalies to be detected”

References

- Secure Software Design By Charles Thies
- Official (ISC)2 Guide to the CSSLP CBK: Second Edition

Additional Resource

Secure Software Design by Prof. Zeller – Saarland University Germany

<https://www.st.cs.uni-saarland.de/edu/secdesign/>

Questions??

zubair.ahmad@giki.edu.pk

Office: G14 FCSE lobby